情報処理安全確保支援士試験　科目A-2　関連分野　中分類4・12 サービスマネジメントとシステム監査　#23

サービスマネジメントとシステム監査

約束したサービスを守り、統制が働いているかを確かめる

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案、JIS Q 20000-1:2020、金融庁 内部統制の基準・実施基準（令和5年）、経済産業省 システム監査基準（令和5年）など）を書いた。過去問は IPA 公開の午前 II 。例の場面は Claude が作った

全体像 シラバス案 中分類4 サービスマネジメント・中分類12 ガバナンス・監査

1 サービスマネジメント
SLA・SLO・SLI、可用性の計算、インシデント管理と問題管理、エスカレーション、変更・構成管理、BIA、継続的改善

2 内部統制
六つの基本的要素、限界、J-SOX、IT 全般統制と業務処理統制、IT の統制目標

3 システム監査
監査基準、保証型と助言型、リスクアプローチ、監査証拠と監査調書、CSA、指摘事項

過去の午前 II での出方（問24・25、H31〜R7 で 21 問）

テーマ	出た回
可用性の計算	R4春・R7春・R7秋
JIS Q 20000・問題管理	R5春・R5秋・R6秋
IT 全般統制・業務処理統制	R4春・R6春・R6秋・R7春
監査（調書・指摘・計画）	ほぼ毎回

出典：IPA「支援士試験 シラバス（案）Ver.0.1」中分類4・12／IPA 午前 II 各回（このPDFの問題演習を参照）

第1章

サービスマネジメント

測って、約束して、止まったら戻し、原因を断つ。

サービスレベルと可用性

SLI
測る指標
→
SLO
目標の値
→
SLA
顧客と文書で合意

稼働率

MTBF ÷（MTBF ＋ MTTR）
例 480 ÷（480+20）= 0.96

> MTBF を延ばす＝信頼性、MTTR を縮める＝保守性。

サービス可用性（R7秋）

4〜6 月、毎日 0〜24 時	91 × 24 = 2,184 h
合意した計画停止を除く	− 84 h → 2,100 h
故障による停止	10 h
可用性	2,090 ÷ 2,100 = 99.52%

R7春：毎日 6〜20 時 × 30 日

420 h のうち提供時間内の停止 7 h → 98.3%
提供時間外の修復 3 h・メンテナンス 8 h は数えない

出典：JIS Q 20000-1:2020／IPA 午前 II R4春 問24・R7春 問24・R7秋 問24

運用のプロセス

管理	目的	ポイント
インシデント管理	できるだけ早く元に戻す	暫定復旧・記録・連絡
問題管理	根本原因を特定し恒久策（R5春）	既知の誤り・傾向分析
変更管理	RFC を評価・承認して変更	標準・通常・緊急の変更
構成管理	CI と版・関係を CMDB に	脆弱性の影響範囲の特定
サービス継続管理	災害でもサービスを続ける	BIA で RTO・RPO を決める

機能的エスカレーション
専門の担当チームへ引き継ぐ

階層的エスカレーション
上位の管理者へ報告し判断を求める

出典：JIS Q 20000-1:2020 8 章／ITIL 4／IPA 令和5年度春期 午前 II 問24

JIS Q 20000-1 の言葉

用語	定義（要約）	出た回
継続的改善	パフォーマンスを向上するために繰り返し行われる活動	**R6秋**
プロセス	インプットを使って意図した結果を得る、相互に関連する一連の活動	**R6秋の誤り**
サービスマネジメント	サービスの計画・設計・移行・提供・改善の活動と資源を指揮・管理する能力とプロセス	**R6秋の誤り**
内部監査	SMS が要求事項に適合しているかを、定めた間隔で確かめる	**R5秋**
マネジメントレビュー	トップが SMS の適切性・妥当性・有効性を見直す	**R5秋の誤り**

ISMS（JIS Q 27001、#08）と同じ「附属書 SL」の共通の構造。内部監査とマネジメントレビューの違いはどちらでも問われる。

出典：JIS Q 20000-1:2020 3 用語及び定義・9.2・9.3／IPA 午前 II R5秋 問24・R6秋 問24

第2章

内部統制

全般統制が土台、業務処理統制が個々の処理を守る。

内部統制の枠組み

四つの目的

業務の有効性・効率性／報告の信頼性／法令等の遵守／資産の保全

六つの基本的要素

統制環境	リスクの評価と対応	統制活動
情報と伝達	モニタリング	IT への対応

内部統制の限界

- 共謀で無効になりうる
- 経営者が無視・無効化しうる
- 想定外の事態・判断の誤り

→ 保証は「合理的」で、絶対ではない

> J-SOX：上場企業の経営者が財務報告に係る内部統制を評価し、監査を受ける。

出典：金融庁「財務報告に係る内部統制の評価及び監査の基準（令和5年）」I 1〜3

IT 全般統制と業務処理統制

IT 全般統制（土台）
システムの開発・保守に係る管理（R6春）／運用・管理／アクセスなどの安全性の確保／外部委託の管理

IT 業務処理統制（個々の処理）
入力情報の完全性・正確性・正当性／エラーの修正と再処理／マスタデータの維持管理／アプリの利用者認証と権限（R4春・R6秋）

> 規程・方針の策定や教育は、IT の統制ではなく全社的な統制の選択肢。

IT の統制目標

有効性・効率性	業務に役立ち、無駄なく
準拠性	法令・規程に従う
信頼性	正確・完全。**取引に漏れ・重複がない**（R7春）
可用性	必要なときに使える
機密性	権限のない者に開示しない

出典：金融庁「財務報告に係る内部統制の評価及び監査に関する実施基準（令和5年）」／IPA 午前 II R4春 問25・R6春 問25・R6秋 問25・R7春 問25

第3章

システム監査

リスクに重点を置き、証拠で結論を支える。

監査の流れ

監査計画
リスクアプローチ
→
予備調査
概要把握・手続書
→
本調査
証拠の入手と評価
→
報告
指摘・改善提案
→
フォローアップ

用語	意味
監査調書	監査人が実施した監査のプロセスを記録したもの。結論の根拠（H31）
監査証拠	運用・保守の記録、アクセスログ、トランザクションログ、監査証跡
保証型／助言型	適切であることを保証する／問題を指摘し改善を助言する
CSA	担当者が自らの統制を評価。監査人は参考にできる

出典：経済産業省「システム監査基準（令和5年）」／IPA 平成31年度春期 午前 II 問25

リスクアプローチ

監査リスク ＝ 固有リスク × 統制リスク × 発見リスク

固有リスク
統制がないとした場合の誤りの起きやすさ

統制リスク
統制で防げない・見つけられない

発見リスク
監査手続で見逃す（監査人が調整できる）

R5春・R7秋で問われた考え方

- **リスクは変化する → 変化と影響に留意し、計画を見直す ← 正解**
- **監査リスクを完全に回避 → できない**
- **全対象に一律・均等に資源 → リスクに応じて配分**
- **「統制リスクと残存リスク」の二つに大別 → 基準にない**

出典：経済産業省「システム監査基準（令和5年）」／IPA 午前 II R5春 問25・R7秋 問25

指摘事項になるもの

場面	指摘事項	適切な管理（指摘しない）
DB の直接修正（R5秋）	ログ上はアプリ経由の更新として記録	事前・事後の承認、作業後に特権 ID を無効化
個人情報管理台帳（R2）	見直しは新たな取得のときだけ	概数での記載、保管場所・期限の記載
本番移行（R1秋）	—	役割と責任を明確にした移行計画がチェックポイント
クラウド導入（R3秋）	—	情報の保全には事業者の信頼性・継続性を確認
SaaS（R4秋）	—	利用者が評価できるのはアプリの利用者 ID

「記録が実態と違う」「定期的でない」「責任がない」は指摘。チェックポイントは、そのリスクに直接効くコントロールを選ぶ。

出典：IPA 午前 II R1秋 問25・R2 問25・R3秋 問25・R4秋 問25・R5秋 問25